INFORME DE SEGURIDAD DE APLICACIÓN

Mi Cliente AG

CRM comercial de Grupo AG

Autoverificación interna con OWASP ASVS 5.0, nivel 2, y estado de remediación

Dato	Valor
Destinatario	Área de Ciberseguridad de Grupo AG
Fecha del informe	20 de octubre de 2026
Versión evaluada	Rama principal (main, commit 54283fc). Se informa aparte del SSO con Entra ID, desarrollado en la rama feature/sso-entra (commit fff95bd), aún sin desplegar
Tipo de evaluación	Autoverificación interna del equipo del proyecto. Sin prueba de penetración externa. No es una certificación
Estándar	OWASP Application Security Verification Standard (ASVS) 5.0.0, nivel 2
Clasificación	Uso interno · Confidencial. Describe debilidades de un sistema interno: no distribuir fuera de los equipos autorizados

Contenido

1. Resumen ejecutivo 3
Resultado 3
Las cuatro brechas de prioridad Alta 3
Avance posterior a la verificación 3
Conclusión 3
Qué se solicita al área de Ciberseguridad 4
2. Alcance y método 5
Componentes evaluados 5
Qué se revisó 5
Qué no se hizo 5
Escala de prioridades 5
3. Resultados por capítulo 6
4. Controles implementados 6
5. Brechas y plan de remediación 8
5.1 Prioridad Alta (4) 8
5.2 Prioridad Media (10 abiertas) 8
5.3 Prioridad Baja (13) 9
6. Inicio de sesión único con Microsoft Entra ID 10
6.1 Diseño 10
6.2 Validación del token 10
6.3 Configuración necesaria en Entra ID 10
6.4 Efecto sobre las brechas 11
7. Dependencias de producción 11
8. Riesgos aceptados 11
9. Próximos pasos 12
Referencias 12

1. Resumen ejecutivo

Este informe resume, para el área de Ciberseguridad, el estado de seguridad de la aplicación Mi Cliente AG. Se basa en una autoverificación del equipo del proyecto contra los 253 requisitos de nivel 1 y 2 del estándar OWASP ASVS 5.0, contrastando código, configuración y pruebas automatizadas, más una auditoría de dependencias realizada el 20 de octubre de 2026.

No incluye prueba de penetración externa ni revisión de los servidores reales, y no constituye una certificación. Su propósito es dar visibilidad y acordar un plan, no aprobar excepciones.

Resultado

Indicador	Valor
Requisitos evaluados (nivel 1 y 2)	253 (70 no aplican a esta aplicación)
Cumplimiento sobre los 183 aplicables	**62 % (113 cumplen · 50 parciales · 16 no cumplen · 4 no verificables)**
Cumplimiento de nivel 1	**74 % (46 de 62 aplicables)**
Brechas abiertas	27: 4 de prioridad Alta, 10 Media y 13 Baja (1 Media adicional ya resuelta)
Dependencias de producción	1 vulnerabilidad alta y 4 moderadas; ninguna crítica

El porcentaje es prudente: lo parcial y lo no verificable se cuentan como no cumplido. El código de la aplicación tiene una base sólida; la distancia con el nivel 2 está sobre todo en la operación y el entorno (transporte seguro, gestión de secretos, registros, dependencias) y en la identidad (contraseña inicial compartida y ausencia de segundo factor mientras se use el acceso local).

Las cuatro brechas de prioridad Alta

- **G-01 · Contraseña inicial compartida:** todos los usuarios nuevos o restablecidos reciben la misma contraseña inicial, sin caducidad.
- **G-02 · Transporte seguro no garantizado en el borde:** HSTS desactivado en el proxy, certificado de QA no público y TLS de producción sin verificar.
- **G-03 · Sin segundo factor de autenticación** mientras se use el acceso local.
- **G-04 · Dependencias vulnerables y sin compuerta:** 1 alta y 4 moderadas, y el análisis de dependencias no se ejecuta en los pipelines.

Avance posterior a la verificación

Se desarrolló el inicio de sesión único con Microsoft Entra ID (ADR-027), con su propia revisión de seguridad interna, sin hallazgos críticos ni altos. **Cuando se habilite con MFA mediante Acceso Condicional, cierra G-03, elimina la causa de G-01 tras el corte y cierra G-23.** Está terminado en una rama y verificado con pruebas automatizadas, pero aún no está desplegado ni probado contra el tenant real (sección 6).

Conclusión

La aplicación está en buen estado para continuar en QA con datos de prueba. **Antes de operar con datos reales en producción se recomienda:** cerrar G-01 a G-04 (en la práctica, habilitar Entra ID con MFA

resuelve G-01 y G-03), verificar en el entorno real los puntos no verificables desde el repositorio, y realizar una prueba de penetración externa.

Qué se solicita al área de Ciberseguridad

- Validar el plan de remediación y las prioridades de este informe.
- Acordar la prueba de penetración externa antes de producción.
- Apoyar la configuración de Entra ID y de Acceso Condicional (sección 6.3).
- Indicar el destino corporativo de registros (SIEM) y la bóveda de secretos para producción.

2. Alcance y método

Componentes evaluados

Componente	Descripción
Aplicación web (SPA)	React y Material UI. El token de acceso vive solo en memoria del navegador; el menú y los permisos en pantalla son solo una ayuda visual
API	NestJS con REST y OpenAPI. Controles globales: límite de peticiones, autenticación y autorización «denegar por defecto»
Base de datos	PostgreSQL con migraciones versionadas y bitácora de auditoría inmutable por disparadores
Borde web	NGINX como proxy: cabeceras de seguridad, límites de tamaño y de peticiones, documentación de la API cerrada
Entorno de QA	Windows Server con NGINX y PostgreSQL locales, sobre HTTPS
Pipelines	Azure DevOps

Qué se revisó

- Código fuente y configuración de la versión indicada, contrastando cada requisito con evidencia concreta (archivo y línea) y sin dar por cumplido nada solo porque lo diga la documentación.
- Pruebas automatizadas que demuestran controles: respuestas 401 y 403, límites, validaciones, aislamiento entre usuarios e inmutabilidad de la bitácora.
- Recuento de los 206 puntos de entrada de la API para confirmar que cada uno declara su política de acceso.
- Auditoría real de dependencias de producción y búsqueda heurística de secretos en el repositorio y su historial.

Qué no se hizo

- Pruebas de penetración, pruebas dinámicas (DAST) ni análisis estático automatizado (SAST).
- Comprobaciones sobre servidores reales: TLS y suites de cifrado, cortafuegos y salida de red, WAF, bóveda de secretos, copias de seguridad, sincronización horaria y envío de registros.
- Auditoría de dependencias de desarrollo (solo las de producción).

Escala de prioridades

Prioridad	Criterio
Alta	Permite tomar cuentas, deja sin protección el transporte o un control declarado no opera. Debe cerrarse antes de producción con datos reales
Media	Reduce de forma apreciable la defensa en profundidad o la capacidad de investigar y responder
Baja	Endurecimiento o verificación pendiente de bajo impacto directo

3. Resultados por capítulo

Requisitos aplicables por capítulo del estándar y su estado. En capítulos con pocos requisitos aplicables (V4, V10) conviene mirar los recuentos más que el porcentaje.

Capítulo	Aplicables	Cumple	Parcial	No cumple	No verif.	Cumplimiento
V1 Codificación y saneamiento	16	16	0	0	0	100 %
V2 Validación y lógica de negocio	11	10	1	0	0	91 %
V3 Seguridad del frontend web	18	11	5	2	0	61 %
V4 API y servicios web	4	1	3	0	0	25 %
V5 Manejo de archivos	9	7	1	1	0	78 %
V6 Autenticación	23	14	5	4	0	61 %
V7 Gestión de sesiones	16	9	4	3	0	56 %
V8 Autorización	6	4	2	0	0	67 %
V9 Tokens autocontenidos	7	6	1	0	0	86 %
V10 OAuth y OIDC	7	5	2	0	0	71 %
V11 Criptografía	9	6	3	0	0	67 %
V12 Comunicación segura	7	1	4	1	1	14 %
V13 Configuración	13	3	7	0	3	23 %
V14 Protección de datos	9	6	1	2	0	67 %
V15 Codificación segura y arquitectura	12	5	5	2	0	42 %
V16 Registro de seguridad y errores	16	9	6	1	0	56 %
V17 WebRTC	0	0	0	0	0	No aplica
Total	**183**	**113**	**50**	**16**	**4**	**62 %**

Los capítulos con menor cumplimiento (V12, V13, V4 y V15) dependen sobre todo de la infraestructura y de procesos que el repositorio no controla por completo: TLS, secretos, configuración del entorno y gestión de dependencias.

4. Controles implementados

Controles comprobados en el código y en las pruebas automatizadas:

- **Autorización «denegar por defecto»:** los 206 puntos de entrada declaran su permiso o una excepción justificada; hay pruebas de 401, 403 y de aislamiento entre usuarios. La asignación de accesos es exclusiva del administrador.
- **Contraseñas y sesiones:** Argon2id, bloqueo de cuenta por intentos fallidos, respuesta de inicio de sesión indistinguible, renovación rotativa de sesión con detección de reutilización y token de acceso solo en memoria.
- **Validación de entrada:** campos no declarados rechazados, SQL parametrizado, neutralización de fórmulas en exportaciones CSV y Excel, y errores sin detalles internos.

- **Archivos adjuntos:** tipo verificado por contenido, límite de tamaño, protección contra archivos comprimidos maliciosos y descarga solo a través de la API tras autorizar.
- **Bitácora de auditoría inmutable:** disparadores en la base de datos impiden modificarla o borrarla dentro del periodo de retención, y la retención solo la cambia quien tiene permiso de configuración.
- **Aislamiento en el navegador:** la caché de datos se vacía al cambiar de usuario y el cierre de sesión voluntario no conserva la ruta de retorno.
- **Cabeceras de seguridad:** política de contenidos (CSP) que no permite scripts en línea, protección contra incrustación en marcos y aislamiento de origen.
- **Datos personales en registros:** los datos de contacto se enmascaran en la bitácora y los registros técnicos redactan los datos sensibles.

5. Brechas y plan de remediación

El responsable indicado es una sugerencia por rol. Las brechas de prioridad Alta tienen una historia de trabajo propuesta en el informe técnico.

5.1 Prioridad Alta (4)

ID	Brecha y riesgo	Remediación propuesta	Responsable
G-01	Contraseña inicial compartida, fija y sin caducidad. Quien conozca esa contraseña y un correo toma cualquier cuenta que aún no haya hecho su primer acceso o haya sido restablecida	Habilitar Entra ID (sección 6) y revocar las credenciales locales; o, si se mantiene el acceso local, credencial aleatoria de un solo uso con caducidad corta	Backend · Seguridad
G-02	Transporte seguro no garantizado en el borde: HSTS comentado en el proxy, certificado de QA no público, TLS de producción sin verificar. Riesgo de interceptación o degradación de la conexión	Activar HSTS de al menos un año con dominio y certificado de una CA de confianza; verificar TLS 1.2/1.3 y suites; añadir una prueba automatizada de cabeceras	DevOps · Seguridad
G-03	Sin segundo factor de autenticación con el acceso local. Una contraseña robada o adivinada basta para entrar	Habilitar Entra ID con MFA por Acceso Condicional antes de producción (desarrollado, pendiente de despliegue)	Arquitectura · Responsable del producto
G-04	1 vulnerabilidad alta y 4 moderadas en dependencias de producción; el análisis de dependencias no se ejecuta en los pipelines y no hay plazos de remediación ni inventario (SBOM)	Actualizar las dependencias afectadas; incluir el análisis en los pipelines de PR y de rama principal (fallar en alta o crítica); fijar plazos (crítica 7 días, alta 14, media 30); generar SBOM	DevOps · Backend · Frontend

5.2 Prioridad Media (10 abiertas)

ID	Brecha	Remediación propuesta
G-05	Sin tiempo de inactividad de sesión ni límite de sesiones simultáneas (una sesión abandonada dura hasta 8 h)	Definir inactividad (p. ej. 30 min) y renovar solo con actividad; política de sesiones simultáneas
G-06	Sin gestión de sesiones ni revocación inmediata de un token de acceso (vigencia de 15 min)	Pantalla de sesiones propias y acción del administrador; invalidación por versión de sesión; reautenticación en acciones críticas
G-07	Lista de contraseñas comunes mínima (19 entradas) y sin comprobación de contraseñas filtradas	Lista local de al menos 3000 contraseñas; se vuelve irrelevante tras el corte a Entra ID
G-08	Archivos adjuntos sin análisis antimalware	Integrar un servicio corporativo de análisis con cuarentena y registro
G-09	Registros técnicos sin envío a un sistema separado; permisos y sincronización horaria sin verificar	Enviar registros de la API y del proxy al SIEM corporativo; fijar permisos; comprobar NTP
G-10	Sin clasificación de datos ni modelo de amenazas; respaldos de QA sin cifrar y en el mismo servidor	Documentar clasificación y modelo de amenazas; cifrar los respaldos y copiarlos fuera del servidor
G-11	CSP con estilos en línea permitidos (no permite scripts)	CSP con nonce por respuesta para la librería de estilos; base-uri 'none'
G-12	Secretos en archivo de configuración en QA, sin bóveda verificada; privilegios de base de datos excesivos en QA	Bóveda de secretos en producción; tres roles de base de datos; retirar valores por defecto

ID	Brecha	Remediación propuesta
G-14	Conexión a PostgreSQL sin TLS exigido y proxy a la API por HTTP (en QA todo es local)	TLS con verificación en producción; red aislada entre proxy y API
G-27	Sin política de gestión de claves (rotación de la clave de firma, custodia)	Documentar el ciclo de vida de las claves; identificador de clave para rotar sin corte

Ya resuelta: G-13 (la caché del navegador no se vaciaba al cerrar sesión).

5.3 Prioridad Baja (13)

ID	Brecha	ID	Brecha
G-15	Reglas de salida de red del servidor sin verificar	G-22	Imágenes de contenedor sin fijar por digest y respaldo de instalación sin lockfile
G-16	Sin pruebas automatizadas de CORS, cabeceras y casos frontera	G-23	Identificación por correo con Entra ID (resuelta en la rama del SSO, pendiente de despliegue)
G-17	El build de producción publica mapas de código fuente	G-24	Cuenta administradora inicial con correo predecible por defecto
G-18	Cookie de sesión sin prefijo __Secure-	G-25	Verificaciones de borde y plataforma pendientes (método TRACE, cabeceras reenviadas, dominio propio de QA)
G-19	Lista de algoritmos de token no declarada (resuelta para Entra ID; pendiente en el acceso local)	G-26	Límite de peticiones en memoria y por IP; los rechazos no se registran
G-20	Refresco y cierre de sesión protegidos solo por SameSite=Lax	G-28	Límites de negocio y reglas de bloqueo sin documento transversal
G-21	Cabeceras duplicadas entre la API y el proxy		

6. Inicio de sesión único con Microsoft Entra ID

Estado: **desarrollado y verificado con pruebas automatizadas; pendiente de despliegue y de la primera prueba contra el tenant real.** Decisión documentada en ADR-027. Todo se probó con tokens y con la librería de Microsoft simulados; es previsible algún ajuste en la primera prueba real en QA.

6.1 Diseño

- **Corte directo:** la aplicación pasa del acceso local a Entra ID sin un periodo con ambos activos. Tras vincular a los usuarios, se revocan las credenciales y sesiones locales.
- **Alta al primer ingreso, sin permisos:** un usuario autorizado en Entra ID que entra por primera vez obtiene una cuenta sin roles; el administrador de la aplicación le asigna el acceso.
- **Restricciones del alta:** solo correos del dominio somosgrupoag.com (parámetro configurable), sin invitados externos, con un interruptor para apagarla. Cada alta queda en la bitácora con los datos personales enmascarados.
- **Vinculación solo por el identificador de Microsoft (oid), nunca por correo:** una cuenta local existente no se vincula sola; el administrador la vincula en lote con un script auditado.
- **Bajas manuales:** quitar a alguien en Entra ID le impide obtener tokens nuevos; la cuenta de la aplicación se suspende manualmente. El token vigente dura su vida útil (aprox. 1 h).

6.2 Validación del token

La API acepta solo tokens de acceso emitidos para ella por el tenant de Grupo AG: firma RS256 contra las claves publicadas por Microsoft, emisor, audiencia, tenant, versión 2.0, vigencia obligatoria, scope delegado requerido y aplicación cliente autorizada. Los permisos siempre salen de la base de datos de la aplicación, nunca de los datos del token. Las rutas públicas no crean cuentas.

6.3 Configuración necesaria en Entra ID

El diseño solo es seguro si el tenant se configura así. Se solicita el apoyo de Ciberseguridad para verificarlo:

#	Requisito	Por qué
1	Asignación de usuarios requerida = Sí en la aplicación empresarial de la API, asignando solo el grupo de usuarios del CRM	Es el control principal de quién puede entrar y provocar el alta automática
2	MFA mediante Acceso Condicional sobre la aplicación, con bloqueo de autenticación heredada	Cierra G-03
3	Tokens de acceso versión 2 (accessTokenAcceptedVersion = 2 en el manifiesto de la API)	La API rechaza los tokens versión 1
4	Consentimiento de usuario desactivado y consentimiento de administrador solo para la aplicación web autorizada	Evita que otra aplicación del tenant obtenga tokens para la API
5	Registros separados para la API y la aplicación web (SPA, sin secreto de cliente)	Sin secretos en el navegador
6	El nombre principal (UPN) de cada usuario es su correo corporativo	Es el correo con el que se crea la cuenta
7	Alertas de inicios de sesión de invitados y de altas masivas, correlacionadas con los eventos de alta de la aplicación	Detección temprana de abuso

6.4 Efecto sobre las brechas

Brecha	Efecto al habilitar el SSO
G-03 Sin segundo factor	**Se cierra con MFA por Acceso Condicional (requisito 2)**
G-01 Contraseña inicial compartida	**Desaparece la causa tras revocar las credenciales locales**
G-23 Identificación por correo	**Resuelta: vinculación solo por oid y tenant**
G-07, G-05 y G-06	G-07 deja de aplicar; G-05 y G-06 pasan a depender en parte de la política de sesión de Entra ID

Revisión de seguridad interna del SSO: sin hallazgos críticos ni altos; los cinco hallazgos medios y los menores fueron corregidos antes de cerrar el desarrollo. Tras el despliegue se recomienda repetir la verificación de los capítulos V6, V9 y V10.

7. Dependencias de producción

Resultado de la auditoría del 20 de octubre de 2026 sobre las dependencias de producción: 5 vulnerabilidades, 1 alta y 4 moderadas, ninguna crítica. La librería de Microsoft incorporada para el SSO no añadió ninguna.

Severidad	Componente afectado	Problema	Corregido en	Alcance estimado
Alta	deepmerge-ts (herramienta de configuración de Prisma)	Agotamiento de pila al fusionar estructuras recursivas	8.0.0	Bajo: no procesa datos de usuarios
Media	uuid (vía exceljs)	Falta de comprobación de límites de búfer	11.1.1	No analizado
Media	react-router	Redirección abierta con barra invertida	7.18.0	Bajo: ningún destino de navegación proviene del usuario
Media	react-router	Inyección en la hidratación del servidor	7.18.0	No aplica: sin renderizado en servidor
Media	js-yaml (vía la documentación de la API)	Consumo de CPU sin límite	5.4.1	Bajo: documentación desactivada en producción

8. Riesgos aceptados

Solo se listan riesgos con una decisión escrita. Este informe no aprueba excepciones: las permanentes requieren un registro de decisión (ADR) y la aprobación del responsable.

ID	Riesgo	Alcance y vigencia	Mitigación
RA-1	En QA, la cuenta de la aplicación es propietaria de la bitácora y podría desactivar sus protecciones	Solo QA, temporal; sin datos productivos	En producción, roles de base de datos separados: la aplicación nunca es propietaria de la bitácora
RA-2	Sin MFA mientras se use el acceso local	Hasta habilitar Entra ID	Se trata como brecha Alta (G-03); no aceptable para producción con datos reales

ID	Riesgo	Alcance y vigencia	Mitigación
RA-3	Certificado autofirmado en QA, con aviso en el navegador	Solo QA, hasta tener dominio propio	Se cierra con G-02 (dominio y certificado ya solicitados)
RA-4	Contraseña del administrador inicial exenta de la política	Alta inicial; obligada a cambiarse al entrar	Cubierto por G-01

9. Próximos pasos

Paso	Acción	Cierra
1	Obtener del administrador del tenant la configuración de la sección 6.3, y de infraestructura el dominio de QA con su certificado	Prerrequisito de G-02 y G-03
2	Desplegar el SSO en QA, probarlo contra el tenant real, vincular a los usuarios y revocar las credenciales locales	G-01, G-03, G-23
3	Activar HSTS y verificar TLS en QA y producción	G-02
4	Actualizar dependencias y activar el análisis de dependencias en los pipelines	G-04
5	Enviar registros al SIEM, definir la bóveda de secretos y cifrar los respaldos fuera del servidor	G-09, G-10, G-12
6	Abordar las brechas de prioridad Media según el plan acordado con Ciberseguridad	G-05 a G-27
7	Prueba de penetración externa y repetición de esta verificación antes de producción	Validación independiente

Referencias

Informe técnico completo con la matriz de los 253 requisitos y la evidencia de cada uno: docs/security/asvs-5.0-L2-2026-10.md (repositorio del proyecto). Decisiones de arquitectura relacionadas: ADR-007 y ADR-027 (Entra ID), ADR-019 (acceso local), ADR-020 (asignación de accesos), ADR-021 (adjuntos) y ADR-025 (inmutabilidad de la bitácora).